

Vulnerability Scanning

Usually minimally invasive:

- unlike penetration test

Port scan:

- Poke around and see what's open

Identify systems:

- And security devices

Test from the outside and inside:

- Don't dismiss insider threats

Gather as much information as possible:

- Well operate gold from trash

Static code analyzer

Static Application. Security Testing (SAST):

- Help identify security flaws

We went over these in 4.1 they aren't perfect and not everything can be identified based on analysis alone. But it's a start with attacks like buffers overflows, data base injections etc. You still have to verify each finding. False positives are an issue

Dynamic analysis or Fuzzing:

Send random input to an application:

- Fault injecting, robustness testing, syntax testing, negative testing

Looking for something out of the ordinary:

- Application crash, server error, exception

1998 class project at the University of Wisconsin:

- Operating system utility program reliability
- Professor Barton Miller
- The fuzz generator

Fuzzing engines and frameworks:

Many different fuzzing options:

- Platform specific, language specific etc.

Very time and processor resource heavy;

- Many different iterations to try
- Many fuzzing engines use high probability tests

Carnegie Mellon computer emergency response team (CERT):

- CERT basic fuzzing framework

Package monitoring:

Some application. Are distributed in a package:

- especially open source
- Supply chain integrity

Confirm the package is legitimate:

- Trusted source
- No added malware
- No embedded vulnerabilities

Confirm a safe package before deployment:

- Verify contents

Threat Intelligence

Research the threats:

- And the threat actors

Data is everywhere

- Hacker group profiles, tools used by the attackers, and much more

Make decisions based on this intelligence:

- Invest in the best prevention

Used by researchers, security operations teams, and others

Open source intelligence (OSINT):

Open source:

- Publicly available sources
- A good place to start

Internet:

- Discussion groups, social media

Government data:

- Mostly public hearings, reports, websites, etc.

Commercial data;

- Maps, Financial reports, databases

Proprietary/third-party intelligence:

- Someone else has already compiled the threat information:
- You can buy it

Threat intelligence service:

- Threat analytics
- Correlation across different data sources

Constant threat monitoring:

- Identify new threats
- Create automated prevention workflows

Information sharing organizations:

Public threat intelligence

- Often classified information

Private threat intelligence:

- Private companies have extensive resources

Needs to share critical security details:

- Real time, high quality cyber threat information sharing

Cyber Threat Alliance (CTA):

- Members upload specifically formatted threat intelligence
- CTA scores each submission and validates other submissions
- Other members can extract and validate their data

Dark web intelligence:

Dark web:

- Overlay networks that use the internet
- Requires specific software and configurations to access

Hacking groups and services:

- Activities
- Tools and techniques
- Credit card sales
- Accounts and passwords

Monitor forums for activity

Penetration testing

Pentest:

- Simulate an attack

Similar to vulnerability scanning:

- Except we actually try to exploit the vulnerabilities

Often Compliance mandate:

- Regular pen testing by a 3rd party

Rules of engagement:

An important document:

- Defines purpose and scope
- Makes everyone aware of the test parameters

Type of testing and schedule:

- On site physical breach, internal test, external test

- Normal working hours, after 6pm only, etc

The rules:

- IP address ranges
- Emergency contacts
- How to handle sensitive information
- In scope and out of scope devices or application

Exploiting vulnerabilities:

Try to break into the system:

- Be careful; this can cause a denial of service or loss of data
- Buffer overflows can cause instability
- Gain privilege escalation

You may need to many different vulnerability types:

- Password brute force
- Social engineering
- Data base injections
- Buffer overflows

You'll only be sure you're vulnerable if you can bypass security:

- If you can get through, the attacker can get through

The process:

Initial exploitation:

- get into the network

Lateral movement:

- Move from system to system
- The inside of the network is relatively unprotected

Persistence:

- Once your there, you need to make sure there's a way back in
- Set up a backdoor, build user accounts, change or verify default passwords

The pivot:

- Gain access to systems that would normally not accessible
- Use a vulnerable system as a proxy or relay

Responsible disclosure program:

It takes time to fix a vulnerability:

- Software changes, testing, deployment etc

Bug bounty programs:

- A reward for discovering vulnerabilities
- Manufacturer creates a fix
- The vulnerability is announced publicly

Analyzing Vulnerabilities

Dealing with false informationL;

False positives:

- A vulnerability is identified that doesn't really exist

This is different than a low severity vulnerability:

- It's real but it's just not critical

False negative:

- A vulnerability exists, but didn't detect it

Update to the latest signatures:

- If you don't know about it, you can't see it

Work with the vulnerability detection manufacturer:

- They may need to update their signatures for your environment'

Prioritizing Vulnerabilities:

Not every vulnerability shares the same priority:

- Some may not be significant
- Others critical

This maybe difficult to determine that's why there's databases and public disclosures like CVSS

National Vulnerability Database

Common Vulnerability Scoring System (CVSS)

Scores change over time when they update the CVSS

CVE:

The vulnerabilities can be cross references online:

- Almost all scanner give you a place to go

CVE is Common Vulnerabilities and Exposures Data base

Vulnerabilities classification:

The scanner looks for everything

- Well not everything, the signatures are the key

Application scans, Desktop, mobile apps

Web application scans:

- Software on a web server

Network scans

- Misconfigured firewalls, Open ports, Vulnerable devices

Exposure Factor:

Loss of value or business activity if the vulnerability is exploited:

- Usually expressed as a percentage

A small DDoS may limit access to to a service:

- 50% exposure factor

A buffer overflow may completely disable a service:

- 100% exposure factor

A consideration when prioritizing:

- Worst possible outcome probably gets priority

Environmental variables:

What type of environment is associated with this vulnerability:

- Internal server, public cloud, test lab

Prioritization and patching frequency:

- A device in an isolated test lab
- A database server in the public cloud
- Which environment get priority

Every environment is different:

- Number and type of users (internal and external):
- Revenue generating application
- Potential for exploit

Industry/organizational impact:

- Some exploits have significant consequences:
- - The type of organization is an important consideration

Risk. Tolerance:

The amount of risk acceptance to an organization:

- its impractical to remove all risk

The timing of security patches:

- Watching immediately doesn't allow for proper testing

Testing takes time:

- While you're testing, you're also vulnerable

There's a middle ground:

- May change based on severity

Vulnerability Remediation

Patching:

The most common mitigation. Technique:

- We know the vulnerability exists
- We have a patch file to install

Scheduled vulnerability/patch notices:

- Monthly, quarterly

Unscheduled patches:

- Zero day, often urgent

This is an ongoing process:

- The patches keep coming
- An easy way to prevent most exploits

Insurance:

Cybersecurity insurance coverage:

- Lost revenue
- Data recovery costs
- Money lost to phishing
- Privacy lawsuit costs

Doesn't cover everything:

- Intentional acts, funds transfers, etc

Ransomware has increased popularity of cybersecurity liability insurance:

- applies to every organization

Segmentation:

Limit the scope of the exploit:

- Separate devices into their own networks/VLANs

A breach would have limited scope:

- It's not as bad as it could be

Can't patch:

- Disconnect from the world
- Air gaps may be required

Use international; NGFWs;

- Block unwanted/unnecessary traffic between VLANs
- Identify malicious traffic on the inside

Used physical segmentation - from domain 3

Logical segmentation with VLANs - Domain 3

Compensating controls:

Optimal security methods may not be available:

- Can't deploy a patch right now
- no internal firewalls

Compensate in other ways:

- Disable the problematic service
- Revoke access to the application
- Limit external access
- Modify internal security controls and software firewalls

Provide coverage until a patch is deployed

Exceptions and exemptions:

Removing the vulnerability is optimal:

- But not everything can be patched

A balancing act:

- Provide the service but also protect the data and systems

Not all vulnerabilities share the same severity:

- Maybe require local log in, physical access, or other

An exception may be an option

Validation of remediation:

The vulnerability is now patched:

- Does the patch really stop the exploit
- Did you patch all vulnerable systems

Rescanning:

- Perform an extensive vulnerability scan

Audit:

- Check remediated systems to ensure the patch was successfully deployed

Verification:

- Manually Confirm security of the system

Reporting:

Ongoing checks are required:

- new vulnerabilities are continuously discovered

Difficult (or impossible) to manage without automation:

- manual checks would be time consuming

Continuous reporting:

- Number of identified vulnerabilities

- Systems patched vs unpatched
- New threat notifications
- Errors exception and exemptions